

REQUERIMIENTOS FUNCIONALES Y REGLAS DE NEGOCIO

1.1. REGLAS DE NEGOCIO (VALIDACIÓN Y RESTRICCIONES) POR CADA PASO DEL PROCEDIMIENTO, CATALOGO Y CLASIFICADOR

Las Reglas de Negocio (RN) se detallan a continuación:

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
RN-0001	Registro de Usuarios	Si un usuario del sistema accede a la funcionalidad de registro de otro usuario, ENTONCES solo podrá registrar determinados tipos de usuarios, según su propio rol y nivel jerárquico: • El Usuario Titular Electo puede registrar más de un "Usuario Delegado", Responsable o Autorizado sólo dentro de su entidad. • El Usuario Titular Designado puede registrar más de un "Usuario Delegado", Responsable o Autorizado dentro de su entidad. • El Usuario Delegado solo puede registrar y administrar Usuarios Responsables y Usuarios Autorizados, dentro del ámbito delegado por el Titular. No puede crear Titulares ni otros Delegados. • El Usuario Responsable solo puede registrar Usuarios Autorizados dentro de su área funcional definida. No puede crear Responsables, Delegados ni Titulares. • El Super usuario solo puede crear usuarios Administrador MEF, Limitado al Ministerio de Economía y Finanzas (MEF). • El usuario Administrador MEF, puede crear el usuario (Operativo) MEF. APLICADO en la funcionalidad de registro de nuevos usuarios del Gestor de Identidad BASADO en el principio de jerarquía de responsabilidades y control institucional.
RN-0002	Unicidad de Usuarios	Si un usuario intenta registrarse, ya sea mediante proceso de autoregistro o a través de un registro administrativo, ENTONCES el sistema debe verificar que no exista otro usuario con el mismo correo electrónico o identificador único (como DNI o RUC) dentro del mismo tenant. SE APLICA A todos los tipos de usuario y modalidades de registro. SE BASA EN el principio de unicidad e integridad de identidad dentro de entornos lógicamente aislados. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permiten excepciones; el sistema deberá rechazar el registro y notificar la condición en caso de duplicidad.
RN-0003	Validación de Sesión Activa	Si un usuario intenta ingresar a la aplicación, ENTONCES el sistema debe permitir el acceso únicamente si el usuario cuenta con una sesión activa válida o si sus credenciales de autenticación son correctas. SE APLICA A todos los puntos de entrada al sistema que requieren autenticación. SE BASA EN el principio de control de acceso y sesión segura para garantizar la identidad del usuario. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite el acceso si la sesión ha expirado o si las credenciales proporcionadas no son válidas

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
RN-0004	Asignación de Roles y perfiles	Si se realiza la asignación de roles o perfiles a un usuario dentro del sistema, ENTONCES dicha asignación debe corresponder estrictamente a los roles y perfiles previamente definidos en la política de seguridad vigente. SE APLICA A todos los procesos de configuración de accesos y gestión de privilegios del Gestor de Identidad. SE BASA EN el principio de control normado de accesos y alineamiento con las políticas institucionales de seguridad, conforme a lo establecido en la norma ISO/IEC 27001:2022, específicamente en los controles del dominio A.5 sobre gestión de identidad y acceso. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite la asignación de roles o perfiles que no estén contemplados en la política de seguridad aprobada por la entidad
RN-0005	Intentos de Autenticación	Si un usuario ingresa credenciales incorrectas más de tres veces consecutivas dentro de un mismo intento de acceso o en un lapso de tiempo configurado (por defecto, 15 minutos), ENTONCES el sistema deberá bloquear temporalmente su cuenta por un periodo de 5 minutos y enviar una notificación automática al correo institucional registrado. SE APLICA A todos los usuarios que acceden al sistema mediante autenticación basada en credenciales. SE BASA EN los controles establecidos por la norma ISO/IEC 27001:2022 para mitigar ataques de fuerza bruta, específicamente en los controles A.5.15 y A.5.16 sobre gestión de accesos y protección contra intentos no autorizados. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permiten excepciones; esta medida debe aplicarse automáticamente ante la detección del umbral de intentos fallidos consecutivos en el rango de tiempo definido por la política de seguridad.
RN-0006	Recuperación de Credenciales	Si un usuario no puede acceder al sistema debido a que las credenciales ingresadas son incorrectas o han sido olvidadas, ENTONCES deberá iniciar el proceso de recuperación de contraseña a través del mecanismo seguro habilitado por el sistema (siguiendo el RF-05), que incluye verificación de identidad mediante correo electrónico o método alternativo autorizado. SE APLICA A todos los usuarios del Gestor de Identidad que requieran restablecer sus credenciales de acceso. SE BASA EN las buenas prácticas de gestión segura de contraseñas según la norma ISO/IEC 27001:2022, en el marco de los controles de autenticación y recuperación segura. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite continuar con el proceso de inicio de sesión hasta que se haya completado exitosamente la recuperación de credencial
RN-0007	Políticas de Contraseña	Si un usuario crea o actualiza su contraseña en el sistema, ENTONCES esta deberá cumplir con las siguientes políticas mínimas de seguridad: tener una longitud no menor a 8 caracteres, incluir al menos una letra mayúscula, un número y un carácter especial, no coincidir con ninguna de las últimas 5 contraseñas utilizadas por el mismo usuario, y contar con una vigencia máxima de 3 meses desde su activación. SE APLICA A todos los usuarios del Gestor de Identidad en los procesos de registro inicial, restablecimiento o cambio de credenciales. SE BASA EN los controles de autenticación segura establecidos en la norma ISO/IEC 27001:2022, específicamente en el dominio A.5 sobre control de acceso, gestión del ciclo de vida de contraseñas y protección contra reutilización de credenciales. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá registrar ni actualizar una contraseña si no se cumplen simultáneamente todos los

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		criterios establecidos; una vez vencido el plazo de vigencia, el sistema bloqueará el acceso al usuario hasta que se complete el cambio obligatorio de contraseña.
RN-0008	Cambio Obligatorio de Contraseña	Si un usuario accede al sistema por primera vez o si su contraseña ha alcanzado el período de vigencia máxima permitido, ENTONCES el sistema deberá exigir el cambio obligatorio de contraseña antes de permitir el uso de cualquier funcionalidad. SE APLICA A todos los usuarios del Gestor de Identidad, sin distinción de tipo o nivel de acceso. SE BASA EN las disposiciones de la norma ISO/IEC 27001:2022 relativas al control del ciclo de vida de las credenciales, especialmente en los controles del dominio A.5 sobre autenticación y gestión de contraseñas. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá el acceso a la plataforma ni siquiera parcialmente hasta que el usuario haya completado exitosamente el cambio de contraseña.
RN-0009	Autenticación Multifactor Obligatoria	Si un usuario tiene habilitada la opción de autenticación multifactor (MFA), ENTONCES deberá completar obligatoriamente un segundo factor de autenticación válido antes de obtener acceso al sistema. SE APLICA A todos los usuarios configurados con MFA en el Gestor de Identidad, independientemente de su tipo o nivel de rol. SE BASA EN los controles de autenticación reforzada definidos en la norma ISO/IEC 27001:2022, específicamente en el dominio A.5 sobre control de acceso y prevención de accesos no autorizados. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá el ingreso al sistema mientras no se haya validado exitosamente el segundo factor de autenticación configurado para el usuario.
RN-0010	Intentos de MFA Limitados	Si un usuario ingresa un código de autenticación multifactor (MFA) incorrecto más de tres veces consecutivas, ENTONCES el sistema deberá bloquear temporalmente su cuenta por un período de 5 minutos y enviar una notificación automática al correo institucional registrado. SE APLICA A todos los usuarios con MFA habilitado durante el proceso de autenticación. SE BASA EN los controles de protección contra accesos no autorizados de la norma ISO/IEC 27001:2022, particularmente en los mecanismos de defensa contra intentos fallidos reiterados establecidos en el dominio A.5. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite el desbloqueo manual anticipado ni el bypass del bloqueo temporal salvo por acción directa de un administrador autorizado.
RN-0011	Verificación de Permisos	Si un usuario intenta acceder a una funcionalidad dentro de la aplicación, ENTONCES el sistema deberá verificar previamente que cuente con los permisos necesarios para dicha operación; de no ser así, deberá denegarse el acceso y habilitarse el procedimiento para que el usuario solicite una actualización de permisos. SE APLICA A todos los puntos de control de acceso en el Gestor de Identidad, incluyendo interfaces internas y externas. SE BASA EN el principio de privilegios mínimos establecido en la norma ISO/IEC 27001:2022, específicamente en el control A.5.18 sobre asignación y revisión de derechos de acceso. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá el acceso a funciones restringidas hasta que los permisos hayan sido actualizados y aprobados por un administrador autorizado.

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
RN-0012	Modificación de Permisos	Si se desea modificar los permisos asignados a un usuario, ENTONCES solo podrá hacerlo un administrador que cuente con privilegios de nivel superior al del usuario objetivo, garantizando así la trazabilidad y la jerarquía en la gestión de accesos. SE APLICA A todas las operaciones de actualización de permisos dentro del Gestor de Identidad, ya sea individuales o masivas. SE BASA EN el principio de control administrativo y segregación de funciones definido en la norma ISO/IEC 27001:2022, particularmente en los controles A.5.15 y A.5.18 sobre gestión de derechos de acceso. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite la modificación de permisos por parte de usuarios sin nivel jerárquico suficiente, aunque cuenten con acceso al módulo de administración.
RN-0013	Registro de Cambios en Auditoría	Si se realiza cualquier cambio relacionado con roles, perfiles, permisos o accesos de usuarios dentro del sistema, ENTONCES dicho cambio deberá ser registrado automáticamente en los logs de auditoría, incluyendo información sobre el autor, fecha, hora y detalle de la modificación realizada. SE APLICA A todas las operaciones administrativas del Gestor de Identidad que afecten la configuración de seguridad o los privilegios de los usuarios. SE BASA EN los controles de trazabilidad y responsabilidad definidos en la norma ISO/IEC 27001:2022, específicamente en los controles A.5.12 y A.5.17 sobre registro de actividades y gestión de eventos. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite excluir ninguna acción de este registro; todos los cambios deben ser auditable sin excepción.
RN-0014	Cierre de Sesión Automático	Si un usuario permanece inactivo dentro del sistema por un periodo superior a 15 minutos, ENTONCES el sistema deberá cerrar automáticamente su sesión activa, requiriendo una nueva autenticación para continuar con el uso de la aplicación. SE APLICA A todos los usuarios del Gestor de Identidad, independientemente de su perfil o nivel de acceso. SE BASA EN los controles de seguridad de sesiones definidos por la norma ISO/IEC 27001:2022, particularmente en el control A.5.30 sobre protección contra accesos no autorizados por sesiones abiertas. Y TIENE LA SIGUIENTE EXCEPCIÓN: no se permite mantener sesiones abiertas más allá del umbral de inactividad establecido; esta política debe aplicarse de manera obligatoria y uniforme. Adicionalmente, al producirse el cierre automático de sesión, el sistema deberá mostrar un mensaje informativo al usuario indicando que su sesión fue finalizada por inactividad, con el objetivo de asegurar la trazabilidad y comprensión del evento.
RN-0015	Restricción de Autoregistro usuario interno	Si un usuario perteneciente a una entidad pública o al Ministerio de Economía y Finanzas (MEF) intenta registrarse en el sistema, ENTONCES el sistema deberá bloquear cualquier intento de autoregistro o autoasignación de permisos o roles, permitiendo únicamente su registro mediante la intervención de un usuario con privilegios administrativos adecuados (Según lo indicado en la RN-0001). SE APLICA A todos los usuarios SIAF(Entidades Públicas) y usuarios MEF. SE BASA EN el principio de control de acceso delegado y autorización jerárquica, conforme a lo establecido en la norma ISO/IEC 27001:2022, específicamente en los controles A.5.15 y A.5.18 sobre administración de privilegios. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite ninguna modalidad de

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		autoregistro para usuarios internos, independientemente del tipo de entidad a la que pertenezcan.
RN-0016	Validación de Usuarios Externos	Si se realiza la creación de un usuario externo dentro del Gestor de Identidad, ENTONCES el sistema deberá validar automáticamente la información del solicitante mediante el servicio de interoperabilidad con SUNAT, asegurando la existencia y vigencia del RUC registrado. SE APLICA A todos los procesos de registro de usuarios externos empresariales que representen personas jurídicas. SE BASA EN el principio de autenticación confiable de terceros y verificación de identidad frente a fuentes oficiales, conforme a los controles A.5.6 y A.5.13 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN la validación solo podrá ser ejecutada por usuarios con rol de administrador, quedando inhabilitada para cualquier otro tipo de operador.
RN-0017	Segmentación por Tenant	Si se realiza la creación, modificación o asignación de usuarios, roles o permisos dentro del Gestor de Identidad, ENTONCES el sistema deberá validar que dichas acciones se efectúen estrictamente dentro del ámbito del tenant al que pertenece el usuario, de acuerdo con el modelo de segmentación definido. SE APLICA A los tres esquemas de operación: • Tenant Aislado: Cada entidad (ministerio, gobierno regional, etc.) es un tenant independiente. Los administradores solo pueden gestionar usuarios, roles y permisos dentro de su entidad. • Tenant Jerárquico: Los pliegos principales actúan como tenants y pueden gestionar usuarios de sus respectivas unidades ejecutoras (UEs) como <i>sub-tenants</i>. - El pliego puede ver las operaciones de sus UEs. - Las UEs solo pueden gestionar su propio ámbito. • Accesos Multi-Tenant: Los usuarios Externos (Usuario Externo Consulta) con roles transversales (como OCI, Contraloría General, MEF o consultores externos autorizados) pueden tener roles y perfiles separados por cada tenant al que acceden. - Debe garantizarse que no se compartan configuraciones ni accesos entre tenants no relacionados. - El sistema debe registrar auditoría separada por tenant. SE BASA EN el principio de segmentación lógica y control de dominio administrativo, conforme a los controles A.5.1, A.5.15 y A.5.17 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá la operación si el identificador del tenant del usuario no corresponde con el objeto sobre el cual se pretende actuar, garantizando la integridad del aislamiento entre entidades
RN-0018	Deshabilitación Automática de Usuarios	Si un usuario no ha registrado actividad dentro del sistema durante un período de inactividad previamente configurado, ENTONCES el sistema deberá deshabilitar automáticamente su cuenta, impidiendo su acceso a la plataforma pero preservando su información histórica y trazabilidad. SE APLICA A todos los usuarios del Gestor de Identidad, sin distinción de rol o tipo de acceso. SE BASA EN los controles

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		de gestión de cuentas inactivas y reducción de riesgos de exposición definidos por la norma NTP-ISO/IEC 27001:2022, particularmente en los controles A.5.15 (gestión de cuentas), A.5.16 (gestión de privilegios) y A.5.19 (desactivación de accesos). Y TIENE LA SIGUIENTE EXCEPCIÓN la reactivación de cuentas deshabilitadas solo podrá ser realizada por un usuario con rol de Administrador Entidad o superior, previa justificación documentada según los procedimientos internos de la entidad.
RN-0019	Creación de perfiles	Si el Gestor de Identidad inicia operaciones en una entidad, ENTONCES el sistema deberá disponer de una serie de perfiles funcionales predefinidos, correspondientes a las funciones transversales del SIAF-RP, que serán precargados automáticamente mediante el módulo de Creación de Perfiles. Estos perfiles representan estructuras estándar del negocio, definidas por el equipo funcional del SIAF-RP, alineadas a roles comunes del ecosistema financiero del Estado (presupuesto, contabilidad, tesorería, inversión pública, etc.), y estarán disponibles para su asignación directa a los usuarios autorizados. SE APLICA A: todas las entidades que utilizan los módulos funcionales del SIAF-RP, en el marco del modelo unificado de gestión financiera del Estado, tanto en esquemas single-tenant como multi-tenant. SE BASA EN: la estandarización operativa promovida por el MEF y los principios de autonomía funcional, trazabilidad y segmentación lógica definidos en la norma ISO/IEC 27001:2022 (controles A.5.6, A.5.7 y A.8.1), garantizando que: • Cada perfil esté obligatoriamente vinculado a una unidad organizacional (según el Clasificador Organizacional); • Exista aislamiento lógico entre entidades (tenants); • En entornos multi-tenant, los perfiles precargados o creados por una entidad no sean visibles, modificables ni reutilizables por otras entidades, incluso si se cuenta con privilegios elevados. Y TIENE LA SIGUIENTE EXCEPCIÓN: los perfiles precargados no podrán ser editados ni eliminados por las entidades, salvo autorización expresa del MEF. ADEMÁS, cada entidad podrá crear sus propios perfiles funcionales personalizados, de acuerdo a sus necesidades operativas y organizacionales, siempre que cumplan con las reglas de vinculación a unidades organizacionales, trazabilidad de permisos y aislamiento por tenant establecidas.
RN-0020	Validación de Combinación Única de Permisos	Si se intenta asignar una combinación de Sistema, Módulo, Rol y Perfil a un usuario, ENTONCES el sistema deberá validar que dicha combinación no se encuentre previamente registrada para el mismo usuario dentro del mismo tenant, rechazando automáticamente cualquier duplicidad. SE APLICA A todos los procesos de asignación de permisos y configuración de accesos personalizados en el Gestor de Identidad. SE BASA EN el principio de unicidad de configuración y consistencia en la gestión de privilegios, conforme a los controles A.5.15 y A.5.18 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite ninguna excepción; cada combinación Sistema-Módulo-Rol-Perfil debe ser única por usuario dentro de su contexto operativo.

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
RN-0021	Validación de unicidad del nombre de rol	Si se realiza el registro o la modificación de un rol dentro del Gestor de Identidad, ENTONCES el sistema deberá validar que el nombre propuesto no coincida con ningún otro rol previamente registrado en el mismo tenant, independientemente de su estado (activo o inactivo), bloqueando el proceso en caso de duplicidad. SE APLICA A todas las operaciones de creación o edición de roles realizadas por usuarios con privilegios administrativos. SE BASA EN el principio de unicidad semántica y trazabilidad de identificadores lógicos, en concordancia con los controles A.5.15 y A.5.17 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá el uso de nombres de rol duplicados bajo ninguna circunstancia, aun cuando el rol original se encuentre deshabilitado o sin asignación activa.
RN-0022	Bloqueo de eliminación de roles en uso	Si se intenta eliminar un rol dentro del sistema, ENTONCES el sistema deberá bloquear la operación si dicho rol está actualmente asignado a uno o más usuarios o perfiles activos, preservando así la consistencia de las configuraciones de acceso. SE APLICA A todas las acciones administrativas de eliminación de roles en el Gestor de Identidad. SE BASA EN los principios de integridad de la configuración de seguridad y prevención de pérdida de referencias lógicas, conforme a los controles A.5.15 y A.5.18 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá eliminar un rol mientras conserve asignaciones activas; en su lugar, podrá inhabilitarse temporalmente bajo trazabilidad administrativa.
RN-0023	Unicidad de nombre de perfil funcional por estructura organizacional	Si se registra o modifica un perfil funcional dentro del sistema, ENTONCES el sistema deberá validar que el nombre propuesto no exista previamente dentro de la misma combinación de Entidad, Unidad Ejecutora, Dependencia y Unidad Organizacional, impidiendo la duplicación de denominaciones funcionales en una misma estructura jerárquica. SE APLICA A todos los procesos de creación o edición de perfiles funcionales en el Gestor de Identidad. SE BASA EN el principio de unicidad lógica y organización estructurada de privilegios, conforme a los controles A.5.15 y A.5.17 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite la reutilización de nombres incluso si el perfil anterior está inactivo o sin asignaciones actuales
RN-0024	Inhabilitación de perfiles en uso requiere validación contextual	Si se intenta inhabilitar un perfil funcional que está actualmente asignado a uno o más usuarios activos, ENTONCES el sistema deberá impedir dicha acción. SE APLICA A todas las acciones administrativas de gestión de perfiles funcionales dentro del Gestor de Identidad. SE BASA EN los principios de trazabilidad, integridad y control de cambios definidos en los controles A.5.12 y A.5.17 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN solo se permitirá la inactivación de perfiles en uso cuando exista una justificación

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		formal registrada y validada por un usuario con privilegios administrativos superiores.
RN-0025	Control de edición restringida según tipo de usuario	Si un usuario intenta modificar la entidad asociada a un perfil funcional, ENTONCES el sistema deberá permitir dicha acción únicamente si el usuario posee el rol de super usuario MEF; en todos los demás casos, este campo debe mostrarse bloqueado y no editable. SE APLICA A las operaciones de administración de perfiles funcionales dentro del Gestor de Identidad. SE BASA EN el principio de segregación de funciones y privilegios diferenciados, conforme a los controles A.5.1 y A.5.15 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permite la edición de este atributo por parte de usuarios que no tengan expresamente el privilegio de super usuario MEF, independientemente de su nivel de acceso dentro de la entidad.
RN-0026	Autoregistro usuario Externo	Si un usuario externo, como un proveedor o representante de una persona jurídica, pertenece al CRUPB, ENTONCES podrá acceder al sistema mediante un proceso de registro controlado exclusivamente por carga masiva, conforme al procedimiento y estructura definidos en el Modelo Funcional Detallado (MFD), el cual establece los roles, perfiles y permisos que serán asignados automáticamente al usuario al momento de su incorporación. Además, la autenticación de estos usuarios se realizará exclusivamente mediante la plataforma de autenticación externa Clave SOL (SUNAT), garantizando la validación previa de identidad con mecanismos oficiales del Estado. SE APLICA A todos los usuarios externos contemplados en el CRUPB, que no pertenecen a entidades del Estado ni al MEF. SE BASA EN el principio de validación previa de identidad y asignación automatizada de privilegios predefinidos, en cumplimiento con los controles A.5.6, A.5.13 y A.5.18 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN: No se requiere validación ni asignación manual posterior por parte de un Usuario Responsable o Administrador MEF, ya que el usuario registrado bajo CRUPB obtiene acceso inmediato al sistema con los privilegios definidos en el MFD, una vez autenticado exitosamente mediante Clave SOL.
RN-0027	Vigencia Credencial temporal	Si se registra un nuevo usuario en el Gestor de Identidad, ENTONCES el sistema deberá generar automáticamente credenciales temporales (contraseña) cuya vigencia no podrá exceder las 72 horas (3 días calendario) desde su emisión; si el usuario no completa el proceso de confirmación de cuenta y cambio de contraseña dentro de ese plazo, dichas credenciales deberán ser inhabilitadas automáticamente. SE APLICA A todos los registros iniciales de usuario, independientemente del tipo o rol. SE BASA EN el principio de autenticación segura y provisión

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		controlada de accesos temporales, conforme a los controles A.5.13, A.5.18 y A.5.19 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN no se permitirá extender el plazo de vigencia ni reutilizar credenciales vencidas; en caso de expiración, deberá generarse un nuevo proceso de registro o activación por parte del administrador autorizado. La contraseñas temporales se deben notificar al correo institucional.
RF-0028	Autenticación de Usuarios mediante ID Perú	Si un usuario externo selecciona como método de acceso la autenticación mediante ID Perú, ENTONCES el sistema deberá redirigir la solicitud al servicio nacional de autenticación interoperable (ID Perú) y validar automáticamente la identidad del usuario con la respuesta firmada digitalmente por la plataforma. SE APLICA A todos los procesos de inicio de sesión de usuarios externos que acceden al SIAF-RP mediante credenciales interoperables del Estado. SE BASA EN el principio de autenticación federada establecido por la Ley N.º 1412 de Gobierno Digital y en los lineamientos de la Secretaría de Gobierno y Transformación Digital de la PCM, así como en los controles A.5.6 y A.5.13 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN el acceso será denegado si la respuesta del servicio de ID Perú no se encuentra debidamente firmada o verificada, registrando el intento como fallido en los mecanismos de auditoría del sistema.
RF-0029	Autenticación de Representantes Legales mediante Clave SOL	Si un usuario externo selecciona como método de acceso la autenticación mediante Clave SOL, ENTONCES el sistema deberá redirigir la solicitud al portal de autenticación de SUNAT, validar la sesión iniciada y recibir la respuesta firmada electrónicamente que confirme la identidad del representante legal. SE APLICA A todos los procesos de inicio de sesión de usuarios que representan a personas jurídicas y que requieren validación con SUNAT como entidad federadora de autenticación. SE BASA EN el principio de autenticación segura de terceros y en la verificación de identidad del representante legal de la persona jurídica a través de servicios oficiales, en cumplimiento con los controles A.5.6 y A.5.13 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN si la respuesta del portal Clave SOL no contiene una firma válida o los datos no corresponden a un representante legal registrado en SUNAT, el sistema deberá denegar el acceso y registrar el evento como intento fallido en la bitácora de auditoría.
RF-0030	Validación de Autoridades Electas mediante JNE	Si un usuario requiere validación como autoridad electa dentro del Gestor de Identidad, ENTONCES el sistema deberá consultar el padrón oficial del Jurado Nacional de Elecciones (JNE) para verificar su condición vigente como titular electo. SE APLICA A todos los procesos donde se requiera confirmar que el usuario ostenta una representación legal o cargo público electo habilitado para actuar en nombre de una entidad estatal. SE BASA EN el principio de control de acceso basado en roles legítimos y funciones oficiales, conforme a los lineamientos de interoperabilidad del Estado peruano y los controles A.5.1, A.5.6 y A.5.13 de la norma ISO/IEC 27001:2022. Y TIENE LA SIGUIENTE EXCEPCIÓN en caso de no encontrarse coincidencia en el padrón del JNE o si el mandato ha expirado, el sistema deberá denegar el acceso asociado a dicha función y notificar al administrador del sistema para su revisión.

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
RN-0031	Registro y Modificación de Sistemas Funcionales	Si un Super Usuario accede al módulo de Gestión de Sistemas Funcionales, ENTONCES podrá registrar un nuevo sistema funcional o modificar uno existente, cumpliendo con las siguientes condiciones: El nombre del sistema funcional debe ser único dentro del Gestor de Identidad. Se debe registrar obligatoriamente la descripción funcional y el propósito del sistema. Toda modificación debe quedar registrada en el historial de cambios, incluyendo: usuario responsable, fecha/hora de edición y campos modificados. No se permite la eliminación física de sistemas funcionales; solo se puede cambiar su estado a "inactivo" para conservar la trazabilidad de asignaciones históricas. SE APLICA A: Exclusivamente al Superusuario del Gestor de Identidad, designado por la Oficina General de Tecnologías de la Información (OGTI) del MEF. SE BASA EN: Principios de control estricto de activos funcionales (ISO/IEC 27001:2022, controles A.5.10 y A.8.1.1). Buenas prácticas de gobernanza de sistemas para evitar la creación no autorizada de sistemas que puedan comprometer la seguridad o trazabilidad.
RN-0032	Registro y Modificación de Módulos Funcionales	Si un superusuario accede al módulo de Gestión de Módulos Funcionales, ENTONCES podrá registrar un nuevo módulo funcional o modificar uno existente, cumpliendo con las siguientes condiciones: El módulo debe estar asociado obligatoriamente a un sistema funcional existente y activo. El nombre del módulo debe ser único dentro del sistema al que pertenece. Se debe registrar la descripción funcional del módulo y su propósito operativo dentro del sistema. Las modificaciones deben conservar un historial con trazabilidad completa: usuario responsable, fecha/hora, campos editados. No se permite la eliminación física de módulos funcionales; solo puede cambiarse su estado a "inactivo" para preservar su historial de uso. SE APLICA A: Solo al Superusuario del Gestor de Identidad, autorizado por la Oficina General de Tecnologías de la Información (OGTI) del MEF. SE BASA EN: Principios de control de estructuras funcionales críticas (ISO/IEC 27001:2022, controles A.5.10 y A.8.2). Necesidad de garantizar la integridad y consistencia del modelo funcional del SIAF-RP.
RN-0033	Generar identificador de autenticación de usuarios	Si se registra un nuevo usuario en el Gestor de Identidad, ENTONCES el sistema deberá asignar un identificador único que será utilizado como nombre de usuario, conforme a la siguiente lógica de autenticación: • Para usuarios internos del MEF, el identificador debe ser ingresado manualmente por el operador del sistema, asegurando que coincida con el usuario previamente creado en el directorio activo institucional (LDAP). • Para usuarios de entidades públicas, el identificador será el número de DNI o CE, utilizado como nombre de usuario para autenticación directa mediante credenciales gestionados por el gestor de identidad. • Para usuarios externos (personas jurídicas o naturales externas al Estado), el sistema utilizará el RUC como identificador para autenticación federada a través de proveedores externos autorizados. SE APLICA A todos los usuarios registrados en el Gestor de Identidad, incluyendo personal del MEF, usuarios institucionales de entidades públicas, y usuarios externos como proveedores o representantes.

NO	NOMBRE DE LA REGLA	DETALLE DE LA REGLA
		SE BASA EN el principio de unicidad, trazabilidad y control de identidades, conforme a los lineamientos de autenticación interoperable del Estado peruano y los controles A.5.17 (información de autenticación) y A.5.13 (gestión de identidad) de la norma ISO/IEC 27001:2022, así como en buenas prácticas de gobierno digital para garantizar la integridad de los registros de usuarios. Y TIENE LA SIGUIENTE EXCEPCIÓN: ● Los usuarios internos del MEF deben tener una cuenta LDAP preexistente. En estos casos: - El identificador debe ser digitado manualmente en el formulario de registro. - La autenticación se realiza mediante LDAP, no se gestionan credenciales locales. ● Los usuarios externos podrán autenticarse mediante mecanismos federados que utilicen el RUC como identificador, tales como Clave SOL (SUNAT), ID Perú u otros servicios reconocidos. En estos casos: - El RUC se utiliza directamente para autenticación. - El sistema mantiene un identificador interno con fines de autorización y trazabilidad.

1.2. REQUERIMIENTOS FUNCIONALES

1.2.1. INVENTARIO DE REQUERIMIENTOS FUNCIONALES

N°	Descripción del Requerimiento Funcional	Reglas de Negocio	Prioridad	Analista que lo elaboró
RF-01	Autenticar a los usuarios mediante un sistema único de acceso centralizado a múltiples aplicaciones.	RN-0001, RN-0002, RN-0003, RN-0005, RN-0007, RN-0009, RN-0013, RN-0017	MUST HAVE	
RF-02	Solicitar un segundo factor de autenticación, cuando el usuario tenga MFA habilitado.	RN-0009, RN-0010, RN-0011, RN-0013, RN-0017	NICE TO HAVE	
RF-03	Gestionar usuarios con validación de identidad mediante servicios externos	RN-0001, RN-0002, RN-0003, RN-0004, RN-0013, RN-0016, RN-0017	SI AF-RP	
RF-04	Solicitar obligatoriamente el cambio de contraseña al primer ingreso del usuario.	RN-0002, RN-0007, RN-0008, RN-0013	SI AF-RP	
RF-05	Permitir el restablecimiento de contraseña mediante un enlace seguro enviado al correo registrado del usuario.	RN-0002, RN-0005, RN-0006, RN-0007, RN-0013, RN-0017		
RF-06	Crear nuevos roles asignándoles nombre, descripción .	RN-0003, RN-0011, RN-0012, RN-0013, RN-0015, RN-0017, RN-0021, RN-0022		
RF-07	Crear nuevos perfiles funcionales por unidad organizacional	RN-0003, RN-0004, RN-0011, RN-0012, RN-0013, RN-0015, RN-0017, RN-0019, RN-0023, RN-0024, RN-0025		

RF-08	Crear nuevas opciones (permisos), de tipo formulario, menú, atributos	RN-0003, RN-0004, RN-0011, RN-0012, RN-0013, RN-0015, RN-0017		
RF-09	Asignar Roles y Perfiles a los usuarios	RN-0003, RN-0004, RN-0011, RN-0012, RN-0013, RN-0015, RN-0016, RN-0017, RN-0020		
RF-10	Crear nuevos Sistemas funcionales	RN-0003, RN-0011, RN-0012, RN-0013, RN-0015, RN-0017		
RF-11	Crear nuevos módulos asociados a los sistemas	RN-0003, RN-0011, RN-0012, RN-0013, RN-0015, RN-0017		
RF-12	Cierra sesión en el sistema	RN-0003 , RN-0013 , RN-0014 , RN-0017		